Primera evaluación de seguridad web

OWASP ZAP sobre Gin & Juice Shop

SQL & Web Security Challenge

Autora: Sofia

Fecha: 27/10/2026

Herramienta: OWASP ZAP 2.17.0 · Sitio: https://ginandjuice.shop/

1. Preparación del entorno

Se instaló OWASP ZAP en Windows junto con Java (Temurin 17, vía winget) y se configuró el navegador para pasar el tráfico por el proxy de ZAP (127.0.0.1:8080). El sitio de pruebas es Gin & Juice Shop, una aplicación deliberadamente vulnerable.

1.1 ZAP abierto

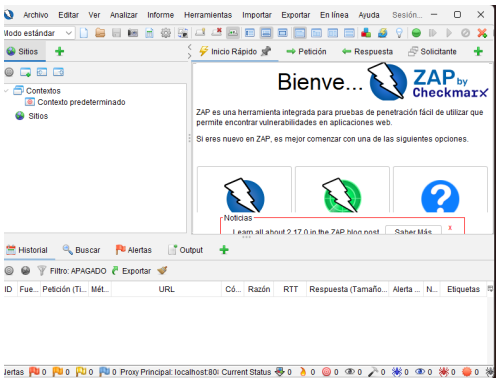


Figura 1. Interfaz principal de ZAP.

1.2 Proxy configurado

La barra de estado de ZAP muestra el proxy principal activo en localhost:8080.



Figura 2. Proxy principal de ZAP: localhost:8080.

1.3 Acceso al sitio

Se accedió a https://ginandjuice.shop/ desde el navegador lanzado con Exploración Manual de ZAP.

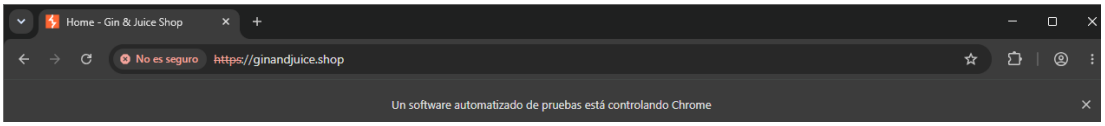
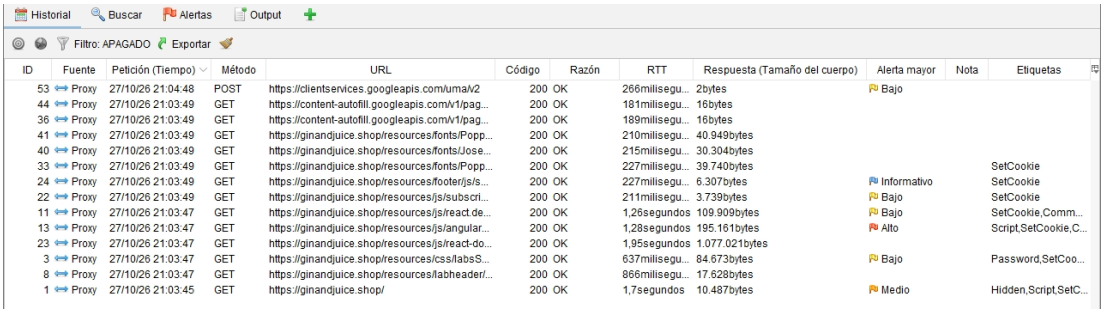


Figura 3. Barra de direcciones con https://ginandjuice.shop/.

1.4 Tráfico visible en ZAP

En la pestaña Historial aparecen las peticiones GET hacia ginandjuice.shop, lo que confirma que el proxy funciona.



ID	Fuente	Petición (Tiempo)	Método	URL	Código	Razón	RTT	Respuesta (Tamaño del cuerpo)	Alerta mayor	Nota	Etiquetas
53	Proxy	27/10/26 21:04:48	POST	https://clientservices.googleapis.com/uma/v2	200	OK	266milisegu...	2bytes	Bajo		
44	Proxy	27/10/26 21:03:49	GET	https://content-autofill.googleapis.com/v1/pag...	200	OK	181milisegu...	16bytes			
36	Proxy	27/10/26 21:03:49	GET	https://content-autofill.googleapis.com/v1/pag...	200	OK	189milisegu...	16bytes			
41	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	210milisegu...	40.949bytes			
40	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/fonts/Jose...	200	OK	215milisegu...	30.304bytes			
33	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	227milisegu...	39.740bytes			SetCookie
24	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/footer/js/s...	200	OK	227milisegu...	6.307bytes	Informativo		SetCookie
22	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/js/subscri...	200	OK	211milisegu...	3.739bytes	Bajo		SetCookie
11	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/js/react.de...	200	OK	1,26segundos	109.909bytes	Bajo		SetCookie,Comm...
13	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/js/angular...	200	OK	1,28segundos	195.161bytes	Alto		Script,SetCookie,C...
23	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/js/react-do...	200	OK	1,95segundos	1.077.021bytes			
3	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/css/labsS...	200	OK	637milisegu...	84.673bytes	Bajo		Password,SetCoo...
8	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/labheader/...	200	OK	866milisegu...	17.628bytes			
1	Proxy	27/10/26 21:03:45	GET	https://ginandjuice.shop/	200	OK	1,7segundos	10.487bytes	Medio		Hidden,Script,SetC...

Figura 4. Historial de ZAP con tráfico de ginandjuice.shop.

2. Exploración de la aplicación

Se navegó por distintas secciones del sitio: página principal, catálogo de productos, detalle de producto, carrito, inicio de sesión y mi cuenta.

2.1 Navegación en el sitio

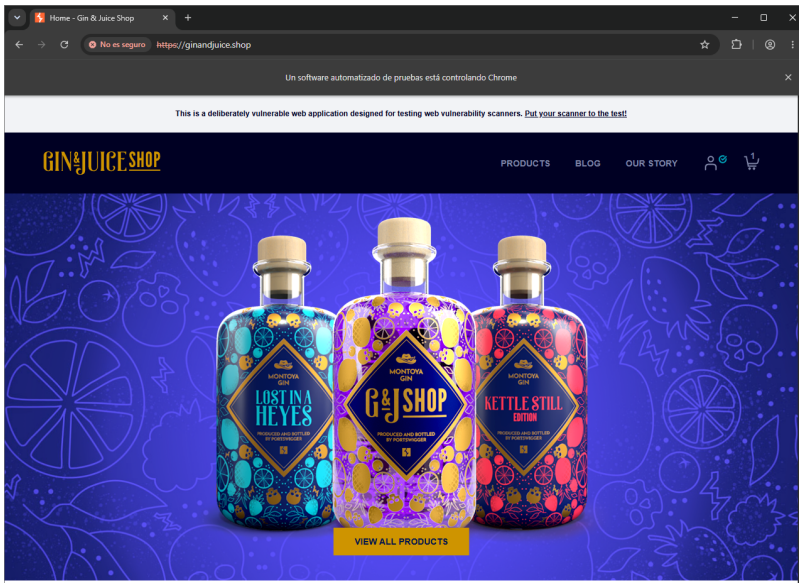
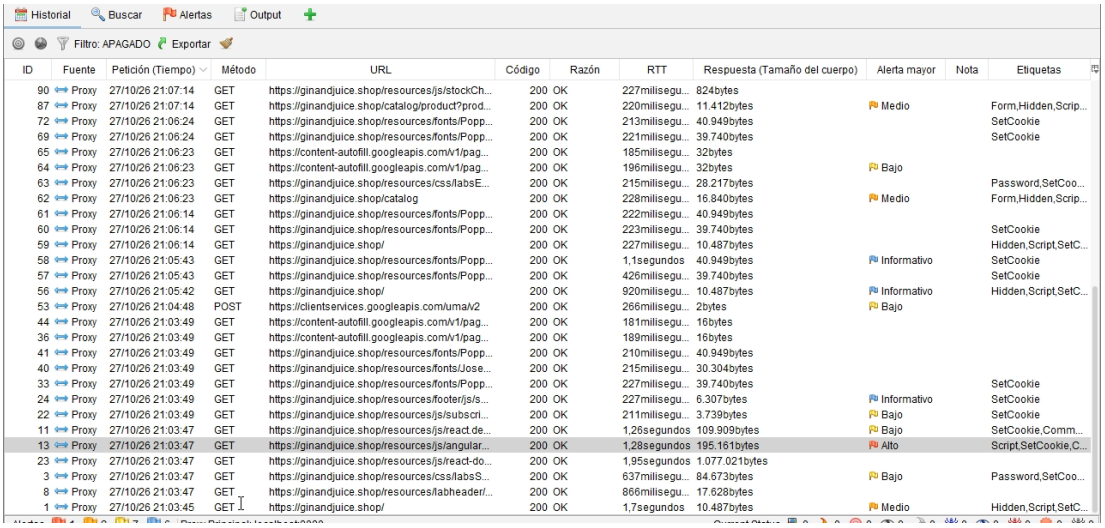


Figura 5. Página principal de Gin & Juice Shop.

2.2 Tráfico HTTP en ZAP



ID	Fuente	Petición (Tiempo)	Método	URL	Código	Razón	RTT	Respuesta (Tamaño del cuerpo)	Alerta mayor	Nota	Etiquetas
90	Proxy	27/10/26 21:07:14	GET	https://ginandjuice.shop/resources/js/stockCh...	200	OK	227milisegu...	824bytes			
87	Proxy	27/10/26 21:07:14	GET	https://ginandjuice.shop/catalog/product?prod...	200	OK	220milisegu...	11.412bytes	Medio		Form,Hidden,Scrip...
72	Proxy	27/10/26 21:06:24	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	213milisegu...	40.949bytes			SetCookie
69	Proxy	27/10/26 21:06:24	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	221milisegu...	39.740bytes			SetCookie
65	Proxy	27/10/26 21:06:23	GET	https://content-autofill.googleapis.com/v1/pag...	200	OK	185milisegu...	32bytes			
64	Proxy	27/10/26 21:06:23	GET	https://content-autofill.googleapis.com/v1/pag...	200	OK	196milisegu...	32bytes	Bajo		
63	Proxy	27/10/26 21:06:23	GET	https://ginandjuice.shop/resources/css/labsE...	200	OK	215milisegu...	28.217bytes			Password,SetCoo...
62	Proxy	27/10/26 21:06:23	GET	https://ginandjuice.shop/catalog	200	OK	228milisegu...	16.840bytes	Medio		Form,Hidden,Scrip...
61	Proxy	27/10/26 21:06:14	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	222milisegu...	40.949bytes			
60	Proxy	27/10/26 21:06:14	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	223milisegu...	39.740bytes			SetCookie
59	Proxy	27/10/26 21:06:14	GET	https://ginandjuice.shop/	200	OK	227milisegu...	10.487bytes			Hidden,Script,SetC...
58	Proxy	27/10/26 21:05:43	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	1,1segundos	40.949bytes	Informativo		SetCookie
57	Proxy	27/10/26 21:05:43	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	426milisegu...	39.740bytes			SetCookie
56	Proxy	27/10/26 21:05:42	GET	https://ginandjuice.shop/	200	OK	920milisegu...	10.487bytes	Informativo		Hidden,Script,SetC...
53	Proxy	27/10/26 21:04:48	POST	https://clientservices.googleapis.com/uma/v2	200	OK	266milisegu...	2bytes	Bajo		
44	Proxy	27/10/26 21:03:49	GET	https://content-autofill.googleapis.com/v1/pag...	200	OK	181milisegu...	16bytes			
36	Proxy	27/10/26 21:03:49	GET	https://content-autofill.googleapis.com/v1/pag...	200	OK	189milisegu...	16bytes			
41	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	210milisegu...	40.949bytes			
40	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/fonts/Jose...	200	OK	215milisegu...	30.304bytes			
33	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/fonts/Popp...	200	OK	227milisegu...	39.740bytes			SetCookie
24	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/footer/js/s...	200	OK	227milisegu...	6.307bytes	Informativo		SetCookie
22	Proxy	27/10/26 21:03:49	GET	https://ginandjuice.shop/resources/js/subscri...	200	OK	211milisegu...	3.739bytes	Bajo		SetCookie
11	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/js/react.de...	200	OK	1,26segundos	109.909bytes	Bajo		SetCookie,Comm...
13	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/js/angular...	200	OK	1,28segundos	195.161bytes	Alto		Script,SetCookie,C...
23	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/js/react-do...	200	OK	1,95segundos	1.077.021bytes			
3	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/css/labsS...	200	OK	637milisegu...	84.673bytes	Bajo		Password,SetCoo...
8	Proxy	27/10/26 21:03:47	GET	https://ginandjuice.shop/resources/labheader/...	200	OK	866milisegu...	17.628bytes			
1	Proxy	27/10/26 21:03:45	GET	https://ginandjuice.shop/	200	OK	1,7segundos	10.487bytes	Medio		Hidden,Script,SetC...

Figura 6. Historial con el tráfico generado al navegar por el sitio.

Otros ejemplos de navegación

El árbol de Sitios muestra las rutas descubiertas: **/catalog** (productos), **/login** (inicio de sesión con POST de usuario y contraseña) y **/my-account** (perfil de usuario).

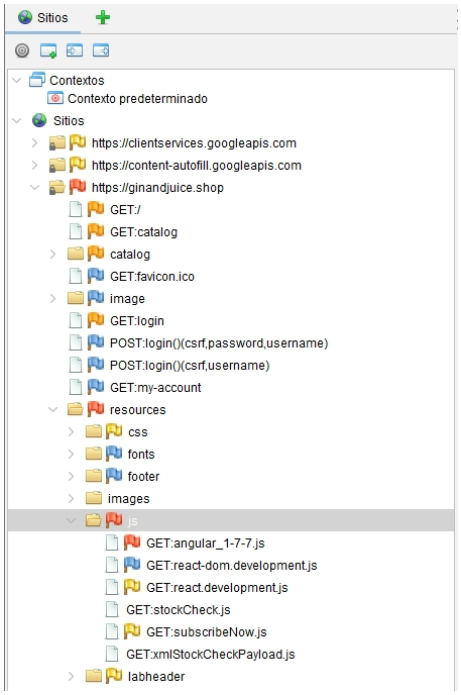


Figura 7. Árbol de sitios con catalog, login y my-account.

Estas secciones permitieron generar tráfico variado: lectura de catálogo, formulario de autenticación y acceso a una página privada.

3. Análisis de alertas

ZAP detectó 16 alertas de forma pasiva (1 alta, 2 medias, 7 bajas y 6 informativas). Se documentan tres de distinto nivel.

3.1 Librería JS Vulnerable (riesgo Alto)

Se detectó AngularJS v1.7.7 en /resources/js/angular_1-7-7.js, versión con vulnerabilidades conocidas.

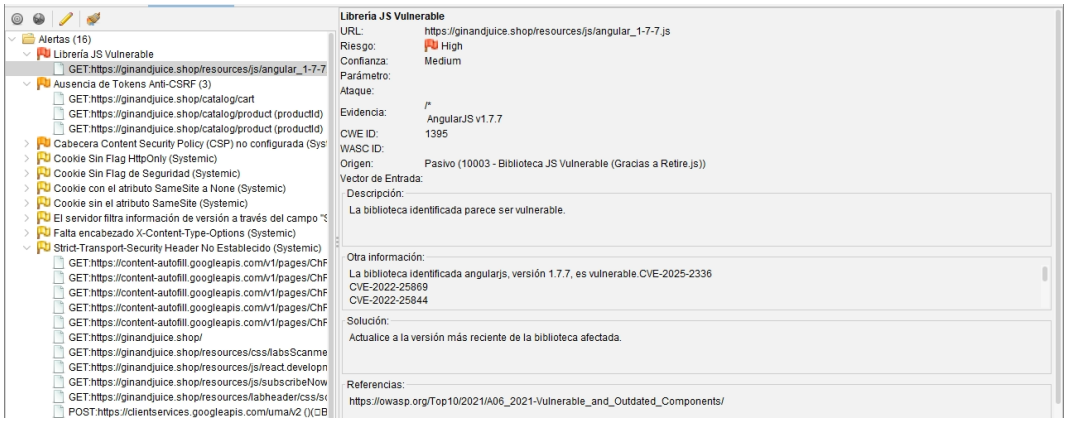


Figura 8. Alerta de riesgo alto.

3.2 Ausencia de Tokens Anti-CSRF (riesgo Medio)

El formulario POST de /catalog/cart no incluye un token anti-CSRF, por lo que un atacante podría forzar acciones en nombre de la víctima.

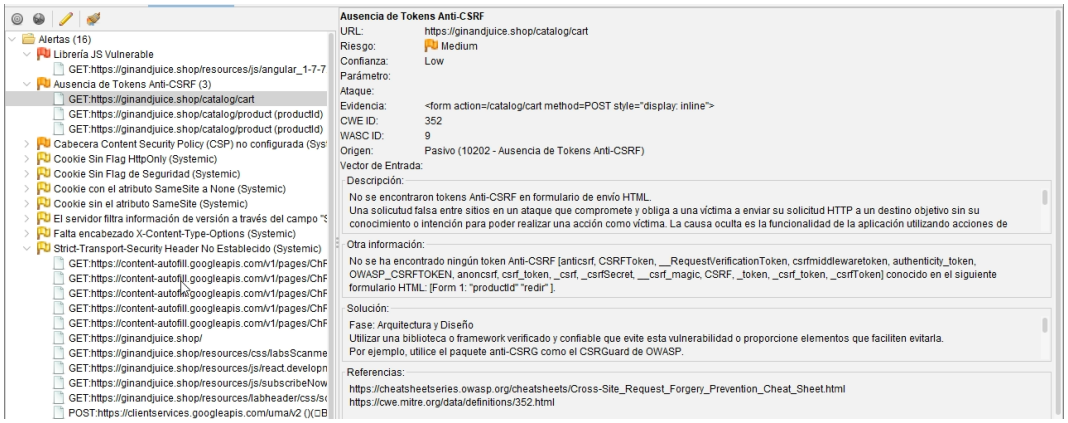


Figura 9. Alerta de riesgo medio.

3.3 Cookie sin flag HttpOnly (riesgo Bajo)

La cookie AWSALB se establece sin HttpOnly, por lo que JavaScript puede acceder a ella.



Figura 10. Alerta de riesgo bajo.

4. Hallazgo principal: ficha técnica

Se eligió la alerta de mayor riesgo.

1. Nombre de la alerta	Librería JS Vulnerable
2. Nivel de riesgo	Alto (High)
3. URL o componente	https://ginandjuice.shop/resources/js/angular_1-7-7.js
4. Parámetro afectado	No aplica
5. Evidencia	AngularJS v1.7.7 (ver Figura 11)
6. Descripción técnica	El sitio carga AngularJS 1.7.7, versión con vulnerabilidades conocidas (CVE-2025-2336, CVE-2022-25869, CVE-2022-25844). Detectada de forma pasiva con Retire.js.
7. Impacto potencial	Un atacante podría aprovechar fallos conocidos de la librería (por ejemplo, XSS) para ejecutar código en el navegador de otros usuarios.
8. Recomendación	Actualizar o migrar a una versión soportada. AngularJS ya no recibe soporte oficial.



Figura 11. Detalle técnico de la alerta en ZAP.

5. Conclusiones

¿Qué aprendí?

ZAP intercepta el tráfico entre el navegador y el sitio y, de forma pasiva, detectó 16 alertas sin atacar la aplicación. Me mostró problemas reales como una librería desactualizada, falta de tokens anti-CSRF y cookies sin HttpOnly.

¿Qué fue lo más retador?

Configurar Java y el proxy del navegador, y entender qué alertas son más importantes. Lo resolví instalando Java con winget y usando Exploración Manual de ZAP.

¿Qué revisaría a continuación?

Un escaneo activo para probar inyección SQL y XSS, y revisar el resto de alertas (CSP, SameSite, HSTS).

Resumen de hallazgos

Riesgo	Nombre	URL	Evidencia
Alto	Librería JS Vulnerable	/resources/js/angular_1-7-7.js	AngularJS v1.7.7
Medio	Ausencia de Tokens Anti-CSRF	/catalog/cart	<form action=/catalog/cart method=POST>
Bajo	Cookie Sin Flag HttpOnly	/	Set-Cookie: AWSALB